Membership/Stripe/RLS extension reference

Apply membership_stripe_migration.sql after consolidated sx v3 only, as trusted owner in staging. This is a non-idempotent extension; not a generic migration over arbitrary membership/profiles tables. Personal tier is stored separately from institutional memberships. Added sponsorship columns never replace role_assignments and are mutated only by trusted contractual activation commands. Institutional subscription provisioning is NOT driven by this personal Stripe worker.

Webhook: Node Express + stripe + pg. Mount raw-body route BEFORE JSON/auth middleware. Separate live/test database environments and secrets. Code intentionally supports one direct Stripe account, one recurring personal item of quantity 1. Stripe Connect, add-ons, usage metering, item mixtures, replacement subscription lifecycle, and multiple personal subscriptions need explicit expansion. Single-account secret/API key pairing must be correct; event.account rejected. Map stripe_customer_id from authenticated server-created checkout, never metadata alone. Seed actual approved Stripe price IDs/cadence/mode into stripe_prices; no placeholders auto-approve a price.

Durable receiver INSERT acknowledges only committed receipt. Unique event IDs deduplicate receipt. Worker uses database job row lock and per-customer advisory lock, fetches current Stripe subscription while serialized, then maps approved price to tier. It does not infer plan from display name, user-editable metadata or an old event snapshot. Paid latest invoice+active status enables tier; explicitly approved trial allows bounded trial tier. A failed/unpaid upgrade retains only prior unexpired access. Paid-through expiration enforced by SQL. canceled/unpaid/incomplete_expired/paused revokes under this reference policy; period-end scheduling retains current access until Stripe actual status/effective date. This conservative policy needs reconciliation and precise proration/refund/grace agreement before production.

Worker locks across network reads: configure Stripe timeout/retries (e.g. bounded timeout and maxNetworkRetries), worker concurrency and DB pool/lock budgets. Retrieve fields differ by Stripe API version; code handles legacy vs item current_period_end but requires SDK/API contract tests. Existing subscription replacement is deliberately rejected when it differs from mapped id; implement reviewed mapping updates for legitimate repurchases. invoice events reconcile mapped current subscription; mapping races retry at most 8 attempts then dead-letter. Persistence failure after rollback can leave pending job for retry; processed jobs are never overwritten by failure update. Payloads contain PII: add retention/minimization/secret handling. Outbox/audit tier-change events are not added by this worker and must be integrated for operational evidence. Dead-letter alerting/approved replay and periodic Stripe-to-local reconciliation must be implemented. Do not treat this as a full finance ledger.

Tests: subscription_tiers_test.sql is executable pgTAP reference with rollback fixtures; all_table_rls_audit.sql checks every table's RLS/grants/write policies. Neither has been run. fixture_manifest_runner.psql FAILS coverage when a table lacks a seeded actor test; fill test_manifest + known rows and execute inside a rollback transaction via psql. It intentionally

cannot certify all-table allow/deny behavior without real fixtures. Public display pages do not require anon database grants. Don't run fixture scripts in production. PostgreSQL roles authenticated/anon are separate from application admin/member/viewer roles. Clients cannot write tier/sponsor/event/price tables or enumerate them. Private helpers rely on trusted owner bypass; no FORCE RLS.

Test acceptance still needs webhook signature/duplicate/out-of-order/live-mode/unknown-price/API-failure/payment-gate tests; concurrency, canceled/expired/trial sponsor policy; all existing table positive/negative fixtures; storage and quota enforcement; and SDK/type compilation. No SQL execution, TypeScript compilation, Stripe configuration, repository deployment or external state change has been performed. Files checked nonempty only.